

AI & Digital Regulation Guide for Companies in Germany

EU and German Laws Governing Artificial Intelligence — A Compliance Reference



32 EU & German laws · regulatory bodies · section references · applicability matrix

Edition: June 2026 · Prepared as an internal compliance reference

How to Use This Guide

This guide consolidates the EU regulations and German national laws that govern, or directly affect, the development, deployment and commercial use of Artificial Intelligence (AI) systems by companies operating in Germany. It is structured so that a compliance, legal or product team can quickly identify **which rules apply to them, who enforces them, and where the binding text lives**.

Two layers of law apply in Germany simultaneously. EU Regulations (e.g. the AI Act, GDPR) are *directly binding* in Germany without national transposition. EU Directives (e.g. NIS2) must be transposed into German statute. German national laws then add or specify obligations on top of the EU framework.

The guide is organised in three tiers: Tier 1 — EU Regulations & Directives binding in Germany; Tier 2 — German national laws of general application; Tier 3 — sector-specific laws (finance, insurance, health, mobility, public sector). A company must comply with **all of Tiers 1–2 that are triggered by its AI use**, plus the Tier 3 laws relevant to its industry.

Reference tables at the end provide: a master index, the competent regulatory authorities, the key sections/articles per law, an applicability matrix by business function, an indicative penalty overview, and a watch-list of pending legislation.

Directly binding EU Regulation — applies as-is	Requires transposition EU Directive — via German law	National German federal / state statute	Watch item Draft / not yet in force
--	--	---	---

Contents

How to Use This Guide	2
Contents	3
Tier 1 — EU Law Binding in Germany	5
1. EU AI Act	5
2. GDPR	5
3. EU Data Act	6
4. Data Governance Act	6
5. DORA	6
6. NIS2 Directive (+ German NIS2UmsuCG)	7
7. Cyber Resilience Act	7
8. Product Liability Directive (new)	7
9. Machinery Regulation	8
10. Digital Services Act	8
11. Digital Markets Act	8
12. eIDAS / eIDAS 2.0	9
Tier 2 — German National Laws of General Application	10
13. KI-MIG (AI Market Surveillance & Innovation Act)	10
14. BDSG (Federal Data Protection Act)	10
15. TDDDG (ex-TTDSG)	10
16. GeschGehG (Trade Secrets Act)	11
17. UrhG (Copyright Act)	11
18. UWG (Unfair Competition Act)	11
19. GWB (Competition Act / Antitrust)	12
20. BGB (Civil Code)	12
21. AGG (Equal Treatment Act)	12
22. BetrVG (Works Constitution Act)	13
23. ArbSchG (Occupational Health & Safety Act)	13
24. StGB (Criminal Code)	13
25. MStV (State Media Treaty)	14
Tier 3 — Sector-Specific Laws	15
26. KWG (Banking Act)	15
27. VAG (Insurance Supervision Act)	15

28. SGB V + DiGAV (Digital Health Apps)	15
29. MDR (Medical Device Regulation)	16
30. StVG + Autonomous Driving Act	16
31. VwVfG (Administrative Procedure Act)	16
32. ProdHaftG (Product Liability Act)	17
Reference Table 1 — Master Index of Laws	18
Reference Table 2 — Regulatory Bodies in Germany	19
Reference Table 3 — Key Sections & Articles at a Glance	20
Reference Table 4 — Applicability Matrix by Business Function	21
Reference Table 5 — Indicative Penalties	22
Reference Table 6 — Watch-List (Pending / Evolving)	22

Tier 1 — EU Law Binding in Germany

EU Regulations apply directly in every Member State. EU Directives (marked) require a German transposing act, which is noted where already enacted.

Tier 1A · Core AI & Data Regulations

1. EU AI Act

Regulation (EU) 2024/1689 — Artificial Intelligence Act

Type	EU Regulation — directly binding
Regulator (DE)	BNetzA (lead market surveillance, via KI-MIG); national notifying & sector authorities; EU AI Office for GPAI
Key articles	Art. 5 (prohibited), Art. 6 + Annex III (high-risk), Art. 9–15 (requirements), Art. 50 (transparency), Art. 51–56 (GPAI), Art. 99 (penalties)
Key dates	Prohibited practices: 2 Feb 2025 · GPAI: 2 Aug 2025 · High-risk: 2 Aug 2026 · Product-embedded high-risk: 2 Dec 2027 (AI Omnibus)
Source	EUR-Lex — eur-lex.europa.eu/eli/reg/2024/1689/oj

What it covers (AI relevance): The core horizontal AI law. Risk-based classification (prohibited / high-risk / limited / minimal), conformity assessment, technical documentation, logging, human oversight, accuracy & robustness, transparency duties, and dedicated obligations for GPAI and systemic-risk models.

Who must comply: Any company that develops, deploys, imports, distributes or uses an AI system affecting people in the EU; providers of general-purpose AI (GPAI) models.

2. GDPR

Regulation (EU) 2016/679 — General Data Protection Regulation

Type	EU Regulation — directly binding
Regulator (DE)	Federal (BfDI) & 16 State Data Protection Authorities (Landesdatenschutzbehörden); DSK coordination
Key articles	Art. 5 (principles), Art. 6/9 (lawful basis), Art. 22 (automated decisions/profiling), Art. 35 (DPIA), Art. 13–15 (transparency)
Key dates	In force since 25 May 2018
Source	EUR-Lex — eur-lex.europa.eu/eli/reg/2016/679/oj

What it covers (AI relevance): Governs all processing of personal data by AI. Art. 22 restricts solely-automated decisions with legal/significant effect; a Data Protection Impact Assessment (DPIA) is required for high-risk AI processing; principles of lawfulness, fairness, transparency, purpose limitation and data minimisation apply to training and inference.

Who must comply: Every company processing personal data of EU individuals with AI systems.

3. EU Data Act

Regulation (EU) 2023/2854 — Data Act

Type	EU Regulation — directly binding
Regulator (DE)	BNetzA (designated national competent authority); BfDI for personal-data aspects
Key articles	Ch. II (data access), Ch. III (B2B), Ch. IV (unfair terms), Ch. VI (cloud switching)
Key dates	In force; applies from 12 Sep 2025
Source	EUR-Lex — eur-lex.europa.eu/eli/reg/2023/2854/oj

What it covers (AI relevance): Harmonised rules on fair access to, and use of, data generated by connected products and AI-enabled services; user rights to access/share device data; restrictions on unfair contractual terms; cloud-switching obligations.

Who must comply: Companies whose AI systems generate or use data from connected (IoT) products and related services; cloud providers.

4. Data Governance Act

Regulation (EU) 2022/868 — Data Governance Act (DGA)

Type	EU Regulation — directly binding
Regulator (DE)	BMDS / BNetzA (competent bodies for data intermediation & data altruism)
Key articles	Ch. II (re-use of public data), Ch. III (data intermediation services), Ch. IV (data altruism)
Key dates	Applies since 24 Sep 2023
Source	EUR-Lex — eur-lex.europa.eu/eli/reg/2022/868/oj

What it covers (AI relevance): Establishes trusted mechanisms for data sharing that feed AI: re-use of protected public-sector data, notification/registration of data-intermediation services, and a framework for data altruism.

Who must comply: Data intermediaries, data-sharing platforms, and organisations re-using protected public-sector data to train AI.

Tier 1B · Cybersecurity, Resilience & Product Safety

5. DORA

Regulation (EU) 2022/2554 — Digital Operational Resilience Act

Type	EU Regulation — directly binding
Regulator (DE)	BaFin (with Deutsche Bundesbank)
Key articles	Art. 5–16 (ICT risk mgmt), Art. 17–23 (incident reporting), Art. 28–44 (third-party/ICT)
Key dates	Applies since 17 Jan 2025
Source	EUR-Lex — eur-lex.europa.eu/eli/reg/2022/2554/oj

What it covers (AI relevance): ICT and AI operational-resilience risk management for the financial sector: governance, incident reporting, resilience testing, and oversight of third-party (incl. AI/cloud) providers.

Who must comply: Banks, insurers, investment firms, payment & crypto-asset service providers, pension funds — any BaFin-regulated financial entity, plus critical ICT third-party providers.

6. NIS2 Directive (+ German NIS2UmsuCG)

Directive (EU) 2022/2555 — transposed by the German NIS-2-Umsetzungsgesetz

Type	EU Directive — requires transposition
Regulator (DE)	BSI (Federal Office for Information Security)
Key articles	Art. 21 (risk-mgmt measures), Art. 23 (incident reporting); German transposition → BSIG
Key dates	German implementing law (BGBl. 2025 Nr. 301) in force 5 Dec 2025
Source	EUR-Lex — eur-lex.europa.eu/eli/dir/2022/2555/oj + BGBl. 2025

What it covers (AI relevance): Cybersecurity risk-management and governance obligations for essential/important entities, including AI-powered infrastructure; mandatory incident reporting to the BSI and management accountability.

Who must comply: Operators of essential and important entities: energy, transport, health, water, digital infrastructure, ICT-service management, public administration, and more (size thresholds apply).

7. Cyber Resilience Act

Regulation (EU) 2024/2847 — Cyber Resilience Act (CRA)

Type	EU Regulation — directly binding
Regulator (DE)	BSI / market-surveillance authorities
Key articles	Annex I (essential cybersecurity requirements), Art. 13–14 (manufacturer obligations, reporting)
Key dates	In force 2024; main obligations apply from 11 Dec 2027 (reporting from Sep 2026)
Source	EUR-Lex — eur-lex.europa.eu/eli/reg/2024/2847/oj

What it covers (AI relevance): Mandatory cybersecurity requirements across the product lifecycle: secure-by-design, vulnerability handling, security updates, and reporting of actively exploited vulnerabilities.

Who must comply: Manufacturers, importers and distributors of products with digital elements — including AI-embedded software and hardware — placed on the EU market.

8. Product Liability Directive (new)

Directive (EU) 2024/2853 — revised Product Liability Directive

Type	EU Directive — requires transposition
Regulator (DE)	Civil courts; transposition by Federal Ministry of Justice (BMJ)
Key articles	Art. 4 (definition incl. software/AI), Art. 7 (defectiveness), Art. 9–10 (burden of proof/disclosure)
Key dates	In force 9 Dec 2024; Germany must transpose by 9 Dec 2026
Source	EUR-Lex — eur-lex.europa.eu/eli/dir/2024/2853/oj

What it covers (AI relevance): Modernises strict liability for defective products to explicitly cover software and AI; eases the claimant's burden of proof and introduces disclosure of evidence for complex AI/software defects.

Who must comply: Manufacturers, importers and (in some cases) providers of AI-powered products and software.

9. Machinery Regulation

Regulation (EU) 2023/1230 — Machinery Regulation

Type	EU Regulation — directly binding
Regulator (DE)	Market-surveillance authorities of the Länder; BAuA guidance
Key articles	Annex III (health & safety, incl. self-evolving behaviour), Art. 6 (high-risk machinery)
Key dates	Applies from 20 Jan 2027
Source	EUR-Lex — eur-lex.europa.eu/eli/reg/2023/1230/oj

What it covers (AI relevance): Safety requirements for AI-powered machinery; explicitly requires risk assessment of self-learning/evolving AI behaviour and interaction between machinery safety and the AI Act.

Who must comply: Manufacturers of industrial AI, robotics, cobots and automated production systems.

Tier 1C · Platform, Market & Identity Regulation

10. Digital Services Act

Regulation (EU) 2022/2065 — Digital Services Act (DSA)

Type	EU Regulation — directly binding
Regulator (DE)	BNetzA — German Digital Services Coordinator; European Commission for VLOPs/VLOSEs
Key articles	Art. 14–15 (T&Cs/transparency), Art. 17 (statements of reasons), Art. 27 & 38 (recommender transparency/choice), Art. 34–35 (systemic-risk)
Key dates	Fully applicable since 17 Feb 2024
Source	EUR-Lex — eur-lex.europa.eu/eli/reg/2022/2065/oj

What it covers (AI relevance): Transparency and accountability for AI recommender systems and content moderation: disclosure of main ranking parameters, options not based on profiling, ad transparency, and systemic-risk assessment of algorithmic systems.

Who must comply: Online platforms, marketplaces, search engines and social networks offering services in the EU; stricter rules for very large platforms/search engines (VLOPs/VLOSEs).

11. Digital Markets Act

Regulation (EU) 2022/1925 — Digital Markets Act (DMA)

Type	EU Regulation — directly binding
Regulator (DE)	European Commission (sole enforcer); Bundeskartellamt supports
Key articles	Art. 5–6 (gatekeeper obligations, anti-self-preferencing), Art. 6(5) (ranking), Art. 6(11) (search data)
Key dates	Applies since 2 May 2023; gatekeeper obligations from Mar 2024
Source	EUR-Lex — eur-lex.europa.eu/eli/reg/2022/1925/oj

What it covers (AI relevance): Constrains AI-driven gatekeeping: bans self-preferencing in algorithmic ranking, restricts use of business users' data to compete, and mandates fair, non-discriminatory ranking.

Who must comply: Designated 'gatekeeper' core-platform providers (e.g. Alphabet, Apple, Meta, Amazon, Microsoft, Booking) and the business users that depend on them.

12. eIDAS / eIDAS 2.0

Regulation (EU) 910/2014, amended by Regulation (EU) 2024/1183

Type	EU Regulation — directly binding
Regulator (DE)	BNetzA (supervisory body for trust services); BSI
Key articles	Trust services (e-signatures, seals, timestamps); EU Digital Identity Wallet framework (2024/1183)
Key dates	Original 2014; eIDAS 2.0 in force 2024; wallets rolling out by 2026
Source	EUR-Lex — eur-lex.europa.eu/eli/reg/2014/910/oj

What it covers (AI relevance): Framework for electronic identification and trust services, increasingly intersecting with AI-based identity verification, KYC automation and authenticity/provenance of digital content.

Who must comply: Providers of trust/identity services and companies relying on electronic identity, signatures or the EU Digital Identity Wallet — relevant for AI identity-verification and anti-fraud systems.

Tier 2 — German National Laws of General Application

These federal (and one inter-state) laws apply across sectors wherever the relevant business activity uses AI. They sit on top of, and supplement, the EU framework in Tier 1.

Tier 2A · AI Governance, Data & Tracking

13. KI-MIG (AI Market Surveillance & Innovation Act)

Gesetz zur Marktüberwachung und Innovationsförderung von künstlicher Intelligenz

Type	German national — government draft (Regierungsentwurf)
Regulator (DE)	Designates BNetzA (lead), BaFin (financial AI), BfArM (medical AI), BAuA (workplace incidents)
Key sections	National competent-authority designation, market-surveillance powers, penalty procedure, sandbox provisions
Key dates	Cabinet draft adopted 10 Feb 2026; parliamentary process ongoing
Source	BMDS / Regierungsentwurf

What it covers (AI relevance): The German implementing statute for the EU AI Act. Designates the national authorities (BNetzA as lead market surveillance authority), sets penalty and coordination procedures, and provides for regulatory sandboxes.

Who must comply: All companies subject to the EU AI Act operating in Germany.

14. BDSG (Federal Data Protection Act)

Bundesdatenschutzgesetz

Type	German national
Regulator (DE)	BfDI (federal) & State Data Protection Authorities
Key sections	§ 26 (employee data), § 22 (special categories), §§ 32–37 (data-subject rights), § 42 (penal)
Key dates	BDSG 2018 (in force 25 May 2018); periodically amended
Source	gesetze-im-internet.de/bdsg_2018/

What it covers (AI relevance): Supplements the GDPR with German specifics: employee-data processing (§ 26) including AI profiling in employment, special-category data, and breach-notification details.

Who must comply: All companies processing personal data in Germany.

15. TDDDG (ex-TTDSG)

Telekommunikation-Digitale-Dienste-Datenschutz-Gesetz (renamed from TTDSG, 14 May 2024)

Type	German national
Regulator (DE)	BfDI; State DPAs; BNetzA (telecom aspects)
Key sections	§ 25 (consent for storage/access on terminal equipment — cookies/tracking), § 19 (confidentiality)
Key dates	TTDSG since 1 Dec 2021; renamed TDDDG effective 14 May 2024
Source	gesetze-im-internet.de/tdddg/

What it covers (AI relevance): Governs consent for storing/accessing information on user devices (cookies, tracking pixels) and confidentiality of communications — directly affecting AI-driven user profiling and ad-tech. *Note: 'TTDSG' was renamed 'TDDDG' on 14 May 2024; the substance is unchanged.*

Who must comply: Any company running AI-powered websites, apps or telemedia/telecom services using cookies, tracking or profiling.

16. GeschGehG (Trade Secrets Act)

Gesetz zum Schutz von Geschäftsgeheimnissen

Type	German national (transposes EU 2016/943)
Regulator (DE)	Civil courts
Key sections	§ 2 (definition), § 3 (lawful acquisition), § 4 (prohibited acts), §§ 6–14 (claims)
Key dates	In force since 26 Apr 2019
Source	gesetze-im-internet.de/geschgehg/

What it covers (AI relevance): Protects confidential business information (model weights, datasets, algorithms, prompts) as trade secrets, provided reasonable protective measures are taken; relevant to AI IP strategy and data-handling contracts.

Who must comply: Companies whose AI models, training datasets, prompts or algorithms constitute protected trade secrets — and those handling third-party confidential data.

Tier 2B · IP, Competition & Consumer Protection

17. UrhG (Copyright Act)

Urheberrechtsgesetz

Type	German national
Regulator (DE)	Civil courts; collecting societies (e.g. GEMA, VG Wort)
Key sections	§ 44a–60h (text & data mining: § 44b general TDM + opt-out, § 60d research TDM), § 69a ff. (software)
Key dates	TDM provisions since 7 Jun 2021 (DSM-Directive transposition)
Source	gesetze-im-internet.de/urhg/

What it covers (AI relevance): Governs AI training data via text-and-data-mining exceptions (§ 44b general TDM, subject to machine-readable opt-out; § 60d for scientific research), the (non-)protectability of AI-generated output, and infringement liability.

Who must comply: Companies training AI on copyrighted material, or commercially generating AI content.

18. UWG (Unfair Competition Act)

Gesetz gegen den unlauteren Wettbewerb

Type	German national
Regulator (DE)	Civil courts; competitors & consumer/industry associations (Verbände)
Key sections	§ 3a (breach of statutory duty), § 5/5a (misleading acts/omissions), § 7 (unsolicited)
Key dates	UWG 2004, frequently amended
Source	gesetze-im-internet.de/uwg_2004/

What it covers (AI relevance): AI-generated advertising must not mislead (§§ 5, 5a); competitors can pursue AI Act breaches as unfair conduct via § 3a; supports labelling duties for automated commercial content.

Who must comply: All companies using AI in marketing, advertising, pricing or product recommendations.

19. GWB (Competition Act / Antitrust)

Gesetz gegen Wettbewerbsbeschränkungen

Type	German national
Regulator (DE)	Bundeskartellamt (Federal Cartel Office); Monopolies Commission
Key sections	§ 18 (market dominance incl. data power/network effects), § 19 (abuse), § 19a (firms of paramount cross-market significance)
Key dates	§ 19a added by 10th GWB amendment, in force 19 Jan 2021
Source	gesetze-im-internet.de/gwb/

What it covers (AI relevance): Antitrust framework for AI: dominance assessment includes data access and network effects (§ 18); abuse prohibited (§ 19); § 19a empowers the Cartel Office to prohibit self-preferencing and data-driven obstruction by firms of paramount significance.

Who must comply: Any company whose AI affects competition, market dominance or access to competition-relevant data.

20. BGB (Civil Code)

Bürgerliches Gesetzbuch

Type	German national
Regulator (DE)	Civil courts
Key sections	§§ 280, 311a, 823 (liability), § 1004 analog (injunction/personality rights), § 312d / Art. 246a EGBGB (consumer info)
Key dates	In force since 1900; continuously amended
Source	gesetze-im-internet.de/bgb/

What it covers (AI relevance): General contractual and tort liability for AI failures (§§ 280, 823), protection against AI deepfakes via personality rights (§ 1004 analog), and consumer-disclosure duties for AI-set prices/terms.

Who must comply: All companies deploying AI in customer-facing or contractual contexts.

Tier 2C · Employment, Anti-Discrimination & Media

21. AGG (Equal Treatment Act)

Allgemeines Gleichbehandlungsgesetz

Type	German national
Regulator (DE)	Federal Anti-Discrimination Agency (ADS); labour & civil courts
Key sections	§ 1 (protected grounds), §§ 7–10 (employment), § 19 (civil-law transactions), § 22 (burden of proof)
Key dates	In force since 18 Aug 2006
Source	gesetze-im-internet.de/agg/

What it covers (AI relevance): Prohibits discrimination by AI systems in hiring, employment and access to services on grounds of race/ethnic origin, gender, religion, disability, age or sexual orientation; the § 22 burden-of-proof shift is significant for opaque algorithmic decisions.

Who must comply: All companies using AI in HR, recruitment or customer decisioning.

22. BetrVG (Works Constitution Act)

Betriebsverfassungsgesetz

Type	German national
Regulator (DE)	Works councils (Betriebsräte); labour courts; conciliation board (Einigungsstelle)
Key sections	§ 87(1) no. 6 (co-determination on monitoring tech), § 90 (workplace design), § 80(3) (AI experts), § 95(2a) (AI guidelines/selection)
Key dates	§§ 80/95 AI provisions clarified by Betriebsrätemodernisierungsgesetz (2021)
Source	gesetze-im-internet.de/betrvg/

What it covers (AI relevance): Works councils have co-determination rights before introducing AI tools that can monitor performance/behaviour (§ 87(1) no. 6); the law expressly references AI for expert consultation (§ 80(3)) and selection guidelines (§ 95(2a)).

Who must comply: Any company with a works council deploying AI that affects employees.

23. ArbSchG (Occupational Health & Safety Act)

Arbeitsschutzgesetz

Type	German national
Regulator (DE)	BAuA; Länder occupational-safety authorities; accident insurers (BG)
Key sections	§ 5 (hazard/risk assessment — Gefährdungsbeurteilung), § 3 (employer duties)
Key dates	In force since 1996; last amended 2024 (BGBl. 2024 I Nr. 236)
Source	gesetze-im-internet.de/arbschg/

What it covers (AI relevance): Requires employers to assess all workplace hazards, expressly including psychological strain from AI monitoring, algorithmic management and automated performance evaluation. BAuA also coordinates EU-level AI-incident notifications under the KI-MIG.

Who must comply: All employers using AI that affects working conditions, monitoring or task allocation.

24. StGB (Criminal Code)

Strafgesetzbuch

Type	German national
Regulator (DE)	Public prosecutors; criminal courts
Key sections	§ 185 (insult), § 186 (defamation), § 187 (calumny), § 130 (incitement), § 201a (image/privacy), § 263 (fraud)
Key dates	In force; 2026 legislative push on deepfake offences (see watch-list)
Source	gesetze-im-internet.de/stgb/

What it covers (AI relevance): AI-generated deepfakes and synthetic media can trigger criminal liability for insult, defamation, incitement, violation of intimate-image privacy (§ 201a) and fraud; a dedicated deepfake offence is in development.

Who must comply: Any company or individual creating or deploying AI capable of generating harmful synthetic media or enabling fraud.

25. MStV (State Media Treaty)

Medienstaatsvertrag der Länder

Type	German inter-state treaty (Länder)
Regulator (DE)	State media authorities (Landesmedienanstalten); die-medienanstalten.de
Key sections	§ 18(3) (bot/automation labelling), §§ 91–96 (media intermediaries & transparency of recommendation)
Key dates	In force since 7 Nov 2020
Source	die-medienanstalten.de

What it covers (AI relevance): Requires disclosure that automation/bots are used where an account appears to be operated by a natural person (§ 18(3)), and imposes transparency/non-discrimination duties on media intermediaries' recommendation systems.

Who must comply: Companies using AI-generated content, bots or recommendation engines on social media/media-intermediary platforms.

Tier 3 — Sector-Specific Laws

A company need only comply with the Tier 3 laws relevant to **its industry**. These add detailed, supervised obligations on top of Tiers 1–2.

Tier 3 · Finance · Insurance · Health · Mobility · Public Sector

26. KWG (Banking Act)

Kreditwesengesetz

Type	German national — sector: finance
Regulator (DE)	BaFin & Deutsche Bundesbank
Key sections	§ 25a (risk management/organisation, incl. algorithms), § 25b (outsourcing)
Key dates	In force; BaFin 'Big Data & AI' principles (2021) operationalise requirements
Source	bafin.de · gesetz-im-internet.de/kredwg/

What it covers (AI relevance): Governs algorithmic decision-making in banking — credit scoring, automated trading and risk models — under BaFin's organisational and risk-management requirements and its supervisory AI principles.

Who must comply: Banks, credit institutions and payment service providers using AI.

27. VAG (Insurance Supervision Act)

Versicherungsaufsichtsgesetz

Type	German national — sector: insurance
Regulator (DE)	BaFin
Key sections	§ 23 (business organisation/governance), §§ 26–32 (risk management, functions)
Key dates	VAG 2016; in force
Source	gesetze-im-internet.de/vag_2016/

What it covers (AI relevance): BaFin oversight of AI in underwriting, automated claims handling and risk-assessment algorithms, under governance and risk-management duties.

Who must comply: Insurance and reinsurance undertakings using AI in underwriting or claims.

28. SGB V + DiGAV (Digital Health Apps)

Sozialgesetzbuch V + Digitale-Gesundheitsanwendungen-Verordnung

Type	German national — sector: healthcare
Regulator (DE)	BfArM (DiGA fast-track); GKV-SV; G-BA
Key sections	§ 33a / § 139e SGB V (DiGA reimbursement & directory); DiGAV (evidence, data protection, interoperability)
Key dates	DiGA fast-track since 2020; DiGAV in force
Source	gesetze-im-internet.de/sgb_5/ · diga.bfarm.de

What it covers (AI relevance): AI-based medical apps (DiGA) must be approved by BfArM, demonstrate a positive healthcare effect, and meet data-protection, security and MDR requirements to be reimbursed by statutory health insurance.

Who must comply: HealthTech companies and medical-AI developers seeking statutory-health-insurance reimbursement.

29. MDR (Medical Device Regulation)

Regulation (EU) 2017/745

Type	EU Regulation — directly binding — sector: medical devices
Regulator (DE)	BfArM; notified bodies; ZLG
Key sections	Art. 10 (manufacturer obligations), Annex I (GSPR), Rule 11 (software classification), Annex IX–XI (conformity)
Key dates	Applicable since 26 May 2021 (transition periods ongoing)
Source	EUR-Lex — eur-lex.europa.eu/eli/reg/2017/745/oj

What it covers (AI relevance): AI qualifying as a medical device (diagnostic AI, clinical decision support) must undergo conformity assessment, obtain CE marking, and meet post-market surveillance and vigilance obligations — interacting with the AI Act's high-risk regime.

Who must comply: MedTech companies with AI diagnostic, monitoring or therapeutic tools.

30. StVG + Autonomous Driving Act

Straßenverkehrsgesetz + Gesetz zum autonomen Fahren (2021) + AFGBV

Type	German national — sector: mobility
Regulator (DE)	KBA (Federal Motor Transport Authority); BMDV
Key sections	§§ 1e–1h StVG (autonomous/automated functions), AFGBV ordinance (operating & approval rules)
Key dates	L3 framework 2017; L4 amendment 28 Jul 2021; AFGBV in force 1 Jul 2022
Source	gesetze-im-internet.de/stvg/ · kba.de

What it covers (AI relevance): Legal framework for Level 3 and Level 4 autonomous vehicles on public roads, including approval, operation and the technical-supervisor role, supplemented by the AFGBV ordinance.

Who must comply: Automotive companies, mobility-as-a-service providers and logistics/AI-driving developers.

31. VwVfG (Administrative Procedure Act)

Verwaltungsverfahrensgesetz

Type	German national — sector: public administration
Regulator (DE)	Administrative courts; public authorities
Key sections	§ 35a (fully automated administrative acts), §§ 39 (reasons), 28 (right to be heard)
Key dates	§ 35a in force since 2017
Source	gesetze-im-internet.de/vwvfg/

What it covers (AI relevance): Permits fully automated administrative decisions only where authorised by law (§ 35a); such decisions must remain explainable, give reasons and be contestable — shaping public-sector AI procurement.

Who must comply: GovTech companies and vendors selling AI software to public authorities.

32. ProdHaftG (Product Liability Act)

Produkthaftungsgesetz

Type	German national — cross-sector (product safety)
Regulator (DE)	Civil courts; BMJ (for the 2026 reform)
Key sections	§ 1 (strict liability), § 3 (defect), § 4 (producer)
Key dates	In force; to be revised by Dec 2026 to transpose EU 2024/2853
Source	gesetze-im-internet.de/prodhaftg/

What it covers (AI relevance): Strict (no-fault) liability for damage caused by defective products, including AI-integrated goods; will be expanded to clearly cover software and AI once the revised EU Product Liability Directive is transposed.

Who must comply: Manufacturers and distributors of AI-integrated products.

Reference Table 1 — Master Index of Laws

#	Law	Reference / German name	Type	Source
1	EU AI Act	Reg (EU) 2024/1689	EU Regulation	EUR-Lex
2	GDPR	Reg (EU) 2016/679	EU Regulation	EUR-Lex
3	Data Act	Reg (EU) 2023/2854	EU Regulation	EUR-Lex
4	Data Governance Act	Reg (EU) 2022/868	EU Regulation	EUR-Lex
5	DORA	Reg (EU) 2022/2554	EU Regulation	EUR-Lex
6	NIS2 + German NIS2UmsuCG	Dir (EU) 2022/2555	EU Directive + DE	EUR-Lex / BGBl.
7	Cyber Resilience Act	Reg (EU) 2024/2847	EU Regulation	EUR-Lex
8	Product Liability Directive	Dir (EU) 2024/2853	EU Directive	EUR-Lex
9	Machinery Regulation	Reg (EU) 2023/1230	EU Regulation	EUR-Lex
10	Digital Services Act	Reg (EU) 2022/2065	EU Regulation	EUR-Lex
11	Digital Markets Act	Reg (EU) 2022/1925	EU Regulation	EUR-Lex
12	eIDAS / eIDAS 2.0	Reg (EU) 910/2014 + 2024/1183	EU Regulation	EUR-Lex
13	KI-MIG	Regierungsentwurf 2026	DE national (draft)	BMDS
14	BDSG	Bundesdatenschutzgesetz	DE national	gesetze-im-internet.de
15	TDDDG (ex-TTDSG)	Tele-Digitale-Dienste-DSG	DE national	gesetze-im-internet.de
16	GeschGehG	Geschäftsgeheimnisgesetz	DE national	gesetze-im-internet.de
17	UrhG	Urheberrechtsgesetz	DE national	gesetze-im-internet.de
18	UWG	Gesetz gg. unlauteren Wettbewerb	DE national	gesetze-im-internet.de
19	GWB	Gesetz gg. Wettbewerbsbeschränkungen	DE national	gesetze-im-internet.de
20	BGB	Bürgerliches Gesetzbuch	DE national	gesetze-im-internet.de
21	AGG	Allg. Gleichbehandlungsgesetz	DE national	gesetze-im-internet.de
22	BetrVG	Betriebsverfassungsgesetz	DE national	gesetze-im-internet.de
23	ArbSchG	Arbeitsschutzgesetz	DE national	gesetze-im-internet.de
24	StGB	Strafgesetzbuch	DE national	gesetze-im-internet.de
25	MSTV	Medienstaatsvertrag	DE state treaty	die-medienanstalten.de
26	KWG	Kreditwesengesetz	Sector — finance	BaFin / g-i-i.de
27	VAG	Versicherungsaufsichtsgesetz	Sector — insurance	gesetze-im-internet.de
28	SGB V + DiGAV	Sozialgesetzbuch V + DiGAV	Sector — health	g-i-i.de / BfArM
29	MDR	Reg (EU) 2017/745	Sector — med devices	EUR-Lex
30	StVG + Autonomous Driving	StVG + Gesetz 2021 + AFGBV	Sector — mobility	kba.de / g-i-i.de
31	VwVfG	Verwaltungsverfahrensgesetz	Sector — public	gesetze-im-internet.de
32	ProdHaftG	Produkthaftungsgesetz	Cross-sector	gesetze-im-internet.de

Reference Table 2 — Regulatory Bodies in Germany

The authorities that supervise, enforce or adjudicate AI-relevant law in Germany.

Body	Full name	Remit (AI relevance)	Primary laws
BNetzA	Bundesnetzagentur (Federal Network Agency)	Lead AI market surveillance (KI-MIG); Digital Services Coordinator (DSA); Data Act; eIDAS trust services	AI Act, DSA, Data Act, eIDAS
BfDI + State DPAs	Federal & State Data Protection Authorities; DSK	Personal-data processing, automated decisions, DPIAs, cookies/tracking	GDPR, BDSG, TDDDG
BaFin	Federal Financial Supervisory Authority	AI in banking, insurance, trading; operational resilience; financial-AI under the AI Act	DORA, KWG, VAG, AI Act (finance)
BSI	Federal Office for Information Security	Cybersecurity, incident reporting, secure products	NIS2/BSIG, CRA, eIDAS
BfArM	Federal Institute for Drugs & Medical Devices	Medical-device AI, DiGA approval; medical-AI under the AI Act	MDR, SGB V/DiGAV, AI Act (medical)
Bundeskartellamt	Federal Cartel Office	Competition, market dominance, data power, self-preferencing	GWB, DMA (support)
BAuA	Federal Institute for Occupational Safety & Health	Workplace hazard assessment; EU AI-incident notifications under KI-MIG	ArbSchG, Machinery Reg.
Federal Anti-Discrimination Agency (ADS)	Antidiskriminierungsstelle des Bundes	Discrimination by AI in employment & services	AGG
KBA	Federal Motor Transport Authority	Approval & oversight of automated/autonomous vehicles	StVG / Autonomous Driving Act
State Media Authorities	Landesmedienanstalten	Bot/automation labelling; media-intermediary transparency	MStV
Works councils / Labour courts	Betriebsräte / Arbeitsgerichte	Co-determination on AI monitoring tools	BetrVG
European Commission / EU AI Office	EU-level	GPAI models & systemic risk; DMA gatekeepers; VLOPs under DSA	AI Act (GPAI), DMA, DSA
Civil & criminal courts	Zivil- / Strafgerichte	Liability, IP, trade secrets, deepfake offences	BGB, UrhG, GeschGehG, StGB, ProdHaftG

Reference Table 3 — Key Sections & Articles at a Glance

Law	Key sections / articles relevant to AI
EU AI Act	Art. 5 (prohibited), Art. 6 + Annex III (high-risk), Art. 9–15 (requirements), Art. 50 (transparency), Art. 51–56 (GPAI)
GDPR	Art. 5 (principles), Art. 6/9 (lawful basis), Art. 22 (automated decisions), Art. 35 (DPIA)
Data Act	Ch. II–IV (access, B2B, unfair terms), Ch. VI (cloud switching)
DGA	Ch. II (public-data re-use), Ch. III (intermediation), Ch. IV (altruism)
DORA	Art. 5–16 (ICT risk), 17–23 (incidents), 28–44 (third-party)
NIS2 / BSIG	Art. 21 (measures), Art. 23 (reporting)
CRA	Annex I (essential requirements), Art. 13–14 (manufacturer, reporting)
Product Liability Dir.	Art. 4 (software/AI), Art. 7 (defect), Art. 9–10 (proof/disclosure)
Machinery Reg.	Annex III (H&S incl. self-evolving AI), Art. 6 (high-risk)
DSA	Art. 14–17 (T&Cs, reasons), Art. 27 & 38 (recommenders), Art. 34–35 (systemic risk)
DMA	Art. 5–6 (gatekeeper duties), 6(5) ranking, 6(11) search data
eIDAS	Trust services; EU Digital Identity Wallet (2024/1183)
BDSG	§ 26 (employee data), § 22, § 42 (penal)
TDDDG	§ 25 (cookie/tracking consent), § 19 (confidentiality)
GeschGehG	§ 2 (definition), § 4 (prohibited acts), §§ 6–14 (claims)
UrhG	§ 44b (general TDM + opt-out), § 60d (research TDM), § 69a ff. (software)
UWG	§ 3a (statutory breach), § 5/5a (misleading)
GWB	§ 18 (dominance/data power), § 19 (abuse), § 19a (paramount significance)
BGB	§§ 280, 823 (liability), § 1004 analog (personality), § 312d (consumer info)
AGG	§ 1 (grounds), §§ 7–10 (employment), § 19, § 22 (burden of proof)
BetrVG	§ 87(1) no. 6 (monitoring), § 80(3) (AI experts), § 95(2a) (AI selection)
ArbSchG	§ 5 (hazard assessment), § 3 (employer duties)
StGB	§ 185–187, § 130, § 201a, § 263
MStV	§ 18(3) (bot labelling), §§ 91–96 (intermediaries)
KWG	§ 25a (risk mgmt/algorithms), § 25b (outsourcing)
VAG	§ 23 (governance), §§ 26–32 (risk mgmt)
SGB V / DiGAV	§ 33a, § 139e SGB V; DiGAV (evidence, security)
MDR	Art. 10, Annex I (GSPR), Rule 11 (software), Annex IX–XI
StVG	§§ 1e–1h (automated/autonomous); AFGBV
VwVfG	§ 35a (automated administrative act), § 39 (reasons)
ProdHaftG	§ 1 (strict liability), § 3 (defect), § 4 (producer)

Reference Table 4 — Applicability Matrix by Business Function

Use this to identify the laws triggered by a given AI use-case. ● = directly applies / highly likely; ■ = applies if sector/condition met.

Business function / AI use	Applicable laws
Any AI system affecting EU persons	● EU AI Act · ● KI-MIG
Processing personal data with AI	● GDPR · ● BDSG · ■ TDDDG (tracking)
Automated decisions / profiling	● GDPR Art. 22 · ● AI Act · ■ AGG (if HR/services)
HR, recruitment, performance monitoring	● AGG · ● BetrVG · ● ArbSchG · ● BDSG § 26 · ● AI Act (high-risk)
Marketing, advertising, dynamic pricing	● UWG · ● GDPR · ■ GWB (if dominant) · ■ MStV (bots)
Training models on copyrighted data	● UrhG (TDM) · ■ GeschGehG · ■ Data Act
Generative AI / deepfakes / synthetic media	● AI Act Art. 50 · ● StGB · ● BGB (personality) · ■ MStV · ■ UrhG
Connected / IoT products generating data	● Data Act · ■ DGA · ■ Machinery Reg.
AI-embedded software / hardware products	● CRA · ● Product Liability · ● ProdHaftG · ■ Machinery Reg.
Online platform / recommender / search	● DSA · ■ DMA (if gatekeeper) · ● GDPR
Critical-infrastructure / essential services	● NIS2/BSIG · ■ DORA (if financial) · ● CRA
Financial services (bank / pay / crypto)	● DORA · ● KWG · ● AI Act · ■ BaFin principles
Insurance underwriting / claims	● VAG · ● AI Act · ● GDPR
Medical / diagnostic AI	● MDR · ■ SGB V/DiGAV · ● AI Act (high-risk) · ● GDPR
Autonomous / automated vehicles	● StVG + Autonomous Driving Act · ● AI Act · ● Machinery (off-road)
AI in public administration / GovTech	● VwVfG · ● AI Act · ● GDPR · ● AGG
Electronic identity / KYC automation	● eIDAS · ● GDPR · ● AI Act

Reference Table 5 — Indicative Penalties

Maximum exposure varies by law; figures are indicative ceilings, not typical fines.

Law	Indicative maximum penalty
EU AI Act	Up to €35m or 7% of global annual turnover (prohibited practices); €15m/3% for most other breaches
GDPR / BDSG	Up to €20m or 4% of global annual turnover
DSA	Up to 6% of global annual turnover (VLOPs)
DMA	Up to 10% of global turnover (20% for repeated infringement)
Data Act	Set by Member States; in Germany via BNetzA — administrative fines
NIS2 / BSIG	Up to €10m or 2% of turnover (essential entities)
CRA	Up to €15m or 2.5% of global turnover
GWB (antitrust)	Up to 10% of global annual turnover
UWG	Injunctions, profit skimming, damages; fines for certain consumer breaches
UrhG / GeschGehG	Injunctions, damages, destruction; criminal liability in aggravated cases
StGB	Criminal: fines or imprisonment depending on offence
MDR	National administrative fines; market withdrawal; CE-mark loss

Reference Table 6 — Watch-List (Pending / Evolving)

Item	Status	Note
AI Omnibus simplification package	EU — proposed/2026	Simplifies & phases AI Act timelines (e.g. product-embedded high-risk to Dec 2027); monitor final text
Deepfake / digital-violence criminal law	DE — BMJ, in development	Would add a dedicated StGB offence for harmful deepfakes & digital violence; could become a new law in 2026–27
Beschäftigtendatengesetz (Employee Data Act)	DE — draft	Would create a standalone statute for employee-data processing & AI in the workplace, beyond BDSG § 26
KI-MIG (final adoption)	DE — Regierungsentwurf Feb 2026	Currently a government draft; final wording on authorities & penalties may shift in the parliamentary process
AI Liability Directive	EU — withdrawn Feb 2025	The proposed AILD was withdrawn; civil AI liability now rests on the revised Product Liability Directive + national law
ePrivacy Regulation	EU — stalled	Intended to replace the ePrivacy framework (and align with TDDDG); status uncertain

Disclaimer. This guide is a structured orientation aid compiled for internal compliance use as of June 2026. It is **not legal advice**. Laws, dates and enforcement practice change — in particular the KI-MIG, the AI Omnibus and several watch-list items are not yet finalised. Always verify the current text against the official sources cited (EUR-Lex, gesetze-im-internet.de, BGBl., and the responsible authority) and obtain qualified legal counsel before relying on any item for a compliance decision.